Response to NCCoE Concept Paper

Software and AI Agent Identity and Authorization

Submitted to: AI-Identity@nist.gov

Reference: NCCoE Concept Paper (Published February 5, 2026)

Prior Engagement: NIST-2025-0035 (Collaborative AI Security Initiative RFI)

Date: March 2026 | Deadline: April 2, 2026

Prepared by: Pratyush Sood, Principal Consultant

Organisation: Tech Blaze Consulting Pty Ltd, Canberra, ACT, Australia

Certifications: CISM, CISA, IRAP, TOGAF, Azure Solutions Architect Expert

Protocol: IDProva — Open protocol for AI agent identity (Apache 2.0)

Website: https://idprova.dev

1. Executive Summary

Tech Blaze Consulting Pty Ltd is an Australian cybersecurity consultancy based in Canberra, ACT. The principal consultant holds CISM (ISACA), CISA (ISACA), IRAP (Australian Cyber Security Centre), TOGAF Enterprise Architecture Practitioner (The Open Group), and Microsoft Azure Solutions Architect Expert certifications, with over 20 years of experience in IT security assessment, compliance, and enterprise architecture.

IDProva is an open protocol for verifiable AI agent identity, licensed under Apache 2.0 and launching April 7, 2026. IDProva provides three protocol primitives — Agent Identity Documents (AIDs), Delegation Attestation Tokens (DATs), and Action Receipts — that collectively address the agent identity, authorization, auditing, and credential lifecycle challenges described in the NCCoE concept paper.

This response demonstrates how IDProva addresses all six NCCoE focus areas:

NCCoE Focus Area	IDProva Coverage	Primary Primitive
Agent Identification	Full	W3C DIDs (AIDs), metadata, configAttestation
Authorization & Scoping	Full	DATs, scope narrowing, constraints, revocation
Auditing & Non-Repudiation	Full	Hash-chained Action Receipts, delegation correlation
Prompt Injection Mitigation	Partial — active development	Config attestation / drift detection
Credential Management	Full	Short-lived DATs, cascading revocation, key rotation
Multi-System Authorization	Full	Protocol bindings (MCP, A2A, HTTP) outside LLM

Tech Blaze Consulting offers IDProva for independent NCCoE evaluation and expresses interest in participating in the demonstration project as a technology contributor and subject matter expert.

2. Use Cases

Enterprise agent delegation chains — A human principal authorises an orchestrator agent, which delegates subsets of authority to worker agents. Each delegation is cryptographically scoped and auditable. The scope narrowing rule prevents privilege escalation at every link.

MCP tool call authorization for sensitive resources — An MCP server validates a DAT before executing any tool call (filesystem read/write, database query, API invocation). Authorization is enforced at the protocol binding layer, outside the LLM reasoning boundary.

Multi-agent compliance audit for regulated environments — Hash-chained Action Receipts provide a tamper-evident audit trail mapping directly to NIST 800-53 (AU-2 through AU-12), Australian ISM, and SOC 2 Trust Services Criteria.

Agent identity lifecycle in CI/CD pipelines — Agents deployed in CI/CD workflows receive time-bounded DATs (24 hours maximum for L0–L1 agents). DATs expire automatically, eliminating stale credentials. Key rotation and AID deactivation are first-class operations.

Cross-organisational agent delegation — When agents from different organisations interact, both resolve each other's DID Documents, verify trust levels, and apply independent trust policies. The interaction proceeds at the lower of the two trust levels.

3. Agent Identification

DID-Based Agent Identity

IDProva agents are identified by W3C Decentralized Identifiers using the did:idprova: method:

```
did:idprova:<authority>:<agent-name>
```

The **authority** is the namespace owner — for domain-verified agents (L1+), the controller proves domain ownership via DNS TXT records. The **agent-name** is locally unique within the authority.

Agent Metadata

Field	Description
name	Human-readable agent name
model	AI model identifier (e.g., anthropic/claude-opus-4)
runtime	Runtime platform (e.g., openclaw/v2.1)
configAttestation	BLAKE3 hash of agent configuration
trustLevel	Current trust level: L0 (Unverified) through L4 (Continuously Monitored)
capabilities	Declared capability strings (e.g., mcp:tool-call, idprova:delegate)
maxDelegationDepth	Maximum delegation chain depth

Configuration Drift Detection

The configAttestation field contains a BLAKE3 hash of the agent's active configuration — system prompt, tool definitions, model identifier, and runtime parameters. If any component changes, the hash changes, and verifiers can detect drift and make trust decisions accordingly.

Resolution

DID Document resolution follows a layered strategy:

1. Local cache (respecting TTL)
2. Well-known endpoint: https://{authority}/.well-known/did/idprova/{agent-name}/did.json
3. Registry lookup: GET /v1/identities/{did}
4. Universal resolver (fallback)

Distinct from Human Users

Agent DIDs are structurally distinct from human user identifiers. The did:idprova: method is agent-specific — it carries agent metadata (model, runtime, config attestation, trust level) that has no analogue in human identity systems. Agents are not users with API keys; they are autonomous entities requiring purpose-built identity semantics.

4. Authorization & Scoped Delegation

Delegation Attestation Tokens (DATs) are JWS-encoded tokens (RFC 7515) that grant scoped authority from one DID to another. They answer: "What is this agent authorised to do, and who authorised it?"

Scope Grammar

```
scope = namespace : resource : action
```

Examples:

- mcp:tool:filesystem:read — Read via filesystem MCP tool
- mcp:tool:database:write — Write via database MCP tool
- a2a:agent:*:communicate — Communicate with any A2A agent
- idprova:delegate — Issue sub-delegations

Scope Narrowing Rule

Each child delegation MUST be a subset of its parent scope. This is enforced structurally — Agent B cannot grant Agent C permissions that exceed Agent B's own authority. This prevents privilege escalation at every delegation step.

Constraints

Constraint	Description
maxActions	Maximum actions per token lifetime
rateLimit	Actions per time window
ipRange	Restrict to specific IP/CIDR ranges
geoRestriction	Limit to specific jurisdictions
maxRedelegationDepth	Maximum further delegation depth
requiredConfigAttestation	Reject if agent config hash drifts

Constraints inherit and narrow through delegation chains — a child cannot weaken a parent's constraint.

Revocation

DATs can be revoked before expiry. Revocation cascades: when a parent DAT is revoked, all child DATs in the delegation chain become invalid. Verifiers check revocation status for every DAT in the chain. Real-time status checks via GET /v1/delegations/{jti}/status.

5. Auditing & Non-Repudiation

Hash-Chained Action Receipts

Every agent action produces a signed Action Receipt — a tamper-evident audit record. Receipts form a hash chain using BLAKE3. Each receipt is signed by the agent's private Ed25519 key (with optional ML-DSA-65 co-signature). The corresponding public key is published in the agent's AID Document.

Receipt Content

- **Who** — agent (DID), delegation (DAT jti → issuer → human principal)
- **What** — action.type (structured taxonomy), action.target, action.parameters
- **When** — timestamp (ISO 8601, millisecond precision, UTC, in signed payload)
- **Where** — context.environment, context.sessionId
- **Outcome** — action.result.status (success, failure, error)

Delegation Correlation

The delegation field in each receipt references the DAT jti that authorised the action. Walking the delegation chain traces authority from any action back to the authorising human principal — complete attribution from

action to identity to authority.

Tamper Evidence

- chain.previousHash — cryptographic link to prior receipt (BLAKE3)
- chain.sequenceNumber — detects insertions and deletions
- signature — Ed25519 (+ optional ML-DSA-65) over the entire receipt payload

Compliance Control Mapping — NIST 800-53 Rev. 5

Control	Description	Receipt Evidence
AU-2	Auditable Events	action.type taxonomy — every action produces a receipt
AU-3	Content of Audit Records	Who, what, when, where, outcome in every receipt
AU-8	Time Stamps	ISO 8601 UTC with milliseconds in signed payload
AU-9	Protection of Audit Information	Hash chain + Ed25519 signatures
AU-10	Non-repudiation	Per-receipt Ed25519 signature + delegation chain
AU-12	Audit Record Generation	Protocol-native, requireReceipt constraint in DATs
IA-2	Identification & Authentication	DID-based identity in every receipt
AC-6	Least Privilege	Delegation scope + constraints

Australian ISM: ISM-0585 (process identification), ISM-0988 (privileged action logging), ISM-0580 (audit log integrity), ISM-1405 (centralised event logging)

SOC 2: CC6.1 (logical access security), CC6.2 (authorised access scope), CC6.3 (audit trail integrity), CC7.2 (system operation monitoring)

6. Prompt Injection Mitigation

IDProva addresses prompt injection from the identity and attestation layer — specifically, detecting when an agent's configuration has been tampered with.

Configuration Attestation

The configAttestation field in AID Documents stores a BLAKE3 hash of the agent's configuration at deployment time (system prompt, tool definitions, model identifier, runtime parameters).

DAT-Level Enforcement

- If the agent's current config hash does not match the attestation in the DAT, validation fails.
- The MCP server rejects the request with idprova:config-mismatch.
- This detects prompt injection attacks that modify the agent's system prompt or tool definitions.

Trust Level Demotion

Agents operating at L4 (Continuously Monitored) can be automatically demoted to a lower trust level if monitoring detects policy violations — including configuration drift that may indicate injection.

Current Scope & Roadmap

What IDProva does: Detects when an agent's configuration has drifted from its attested baseline. Rejects DATs when config attestation mismatches. Provides trust demotion on policy violations.

What IDProva does not yet do: Runtime input filtering, output sanitization, or LLM-layer defenses against adversarial prompts injected via user input or tool results.

The team is actively working to extend prompt injection coverage, including tighter integration between config attestation and runtime monitoring, and exploring partnerships with LLM-layer defense providers to deliver a more comprehensive solution.

7. Credential Lifecycle Management

Short-Lived Delegation Tokens

Trust Level	Maximum DAT Lifetime
L0 (Unverified)	24 hours
L1 (Domain-Verified)	24 hours
L2 (Org-Verified)	7 days
L3 (Third-Party Attested)	7 days
L4 (Continuously Monitored)	7 days

DATs expire automatically — no manual revocation needed for time-bounded tokens.

Revocation

- Per-token revocation via POST /v1/delegations/{jti}/revoke
- Cascading revocation: parent DAT revoked → all child DATs in the chain become invalid
- AID deactivation: deactivating an agent's AID invalidates all DATs where that agent is the subject

Key Rotation

Algorithm	Rotation Period	Mechanism
Ed25519	Every 90 days	DID Document update — add new key, transition, remove old key
ML-DSA-65	Every 180 days	Same mechanism — old and new keys coexist during transition
Emergency	Immediate	Upon suspected compromise — immediate key revocation

Key Storage Hierarchy

1. HSM — FIPS 140-2 Level 2+ certified hardware security modules
2. TPM — Trusted Platform Module for device-bound agents
3. OS Keychain — macOS Keychain, Windows DPAPI, Linux Secret Service
4. Encrypted File — AES-256-GCM with Argon2id key derivation

8. Multi-System Authorization Enforcement

IDProva's protocol bindings enforce authorization outside the LLM reasoning boundary. The LLM never decides whether an action is authorized — cryptographic verification at the binding layer makes that determination

before the action executes.

MCP Binding

1. Agent presents DAT in the initialize request
2. Server decodes the JWS, verifies signature(s), resolves the issuer's DID Document
3. Server verifies the delegation chain (signature + scope narrowing at each step)
4. Server extracts effective scopes and constraints
5. On each tools/call, server checks the required scope against the DAT
6. If receiptRequested is true, server generates an Action Receipt

The LLM cannot bypass this — scope validation is cryptographic (JWS signature verification), not prompt-based.

A2A Binding

For agent-to-agent communication, the sending agent includes its DAT in the task metadata. The receiving agent validates the DAT and checks the appropriate scope before proceeding.

HTTP Binding

For direct HTTP interactions, the DAT is carried in the Authorization header. The HTTP endpoint validates the DAT before processing the request. IDProva-specific error codes provide clear rejection reasons (invalid-dat, insufficient-scope, constraint-violation, delegation-revoked).

Why This Matters

- **Cryptographic** — JWS signature verification, not LLM reasoning
- **External** — Validated at the transport/binding layer, not inside the agent
- **Auditable** — Every authorized action can produce a signed receipt
- **Non-bypassable** — The agent's LLM cannot override a failed DAT validation

9. Standards & Interoperability

Standard	Usage in IDProva
W3C DIDs	Agent identity (AID Documents)
JWS (RFC 7515)	DAT encoding and signature
FIPS 186-5	Ed25519 signatures (classical)
FIPS 204	ML-DSA-65 signatures (post-quantum)
BLAKE3	Receipt hash chains, config attestation
RFC 8785 (JCS)	Canonical serialization for hash input

Relationship to Existing Systems

Complementary to OAuth 2.0/OIDC — IDProva is not a replacement for OAuth. OAuth handles human-to-service authorization. IDProva adds agent-specific semantics: delegation chains, scope narrowing, config attestation, trust levels, and hash-chained audit.

Complementary to SPIFFE/SPIRE — SPIFFE provides workload identity in infrastructure. IDProva adds delegation chains, scoped permissions, and tamper-evident audit trails.

MCP-native — IDProva includes a full MCP protocol binding specification. DATs are validated at the MCP server before tool execution. Receipts are returned in MCP responses.

Post-Quantum Ready

IDProva uses a hybrid Ed25519 + ML-DSA-65 signature scheme from day one. An attacker must break both algorithms to forge a signature.

Phase	Timeline	Action
Phase 0 (Current)	2026	Hybrid Ed25519 + ML-DSA-65; classical-only fallback permitted
Phase 1	2027	Classical-only mode deprecated (advisory)
Phase 2	2028	Classical-only mode deprecated (warning)
Phase 3	2029+	Evaluate ML-DSA-87 as default PQC algorithm

10. Technology Collaboration Interest

Tech Blaze Consulting offers IDProva for independent NCCoE evaluation and expresses interest in contributing to the demonstration project through the following mechanisms.

Open Source Technology Contribution

IDProva is licensed under Apache 2.0 — NCCoE can freely evaluate, integrate, and demonstrate the protocol without licensing agreements.

Component	Description	Status
Rust SDK	Reference implementation (idprova-core crate)	33 tests passing
Python SDK	PyO3 bindings (pip install idprova)	Built from Rust core
TypeScript SDK	napi-rs bindings (@idprova/core)	Built from Rust core
CLI Tool	9 commands covering full agent lifecycle	Ready for integration
Self-Hosted Registry	Docker image for AID registration and DAT management	Final testing

Community of Interest Participation

Tech Blaze Consulting requests membership in the NCCoE Community of Interest (CoI) for this project. As an international technology contributor, we can provide:

- Protocol author perspective — deep understanding of design decisions, trade-offs, and edge cases
- Multi-framework compliance mapping — existing mappings to NIST 800-53, Australian ISM, and SOC 2
- Cross-jurisdictional insight — experience with both US (NIST) and Australian (ISM/ACSC) frameworks

Subject Matter Expert Availability

The principal consultant is available for consulting engagements, presentations, or technical workshops with the NCCoE team. Areas of expertise:

- AI agent identity protocol design and cryptographic architecture

- Compliance assessment methodology for autonomous AI systems (CISM, CISA, IRAP, TOGAF)
- Enterprise architecture for agent delegation and authorization (Azure Solutions Architect Expert)
- Multi-framework security control mapping (NIST 800-53, ISM, SOC 2)

CAISI Listening Sessions

Tech Blaze Consulting will request attendance at the April 2026 CAISI Listening Sessions (via caisi-events@nist.gov by March 20) and is available to present IDProva's approach to the six NCCoE focus areas.

Contact

Pratyush Sood
Principal Consultant — CISM, CISA, IRAP, TOGAF, Azure Solutions Architect
Tech Blaze Consulting Pty Ltd
techblaze.com.au | https://idprova.dev